

一般公開向け文書

ODRE PQC v0.2.9

公開技術白書

日本語版

公開版・2026年9月2日

目次

- 1. エグゼクティブサマリー
- 2. 製品の目的と範囲
- 3. アーキテクチャ
- 4. 暗号プロファイル
- 5. セキュリティ契約
- 6. 脅威モデルと信頼境界
- 7. 検証と監査結果
- 8. クロスプラットフォーム結果
- 9. リリース規律と証拠
- 10. 導入ガイダンス
- 11. 公開範囲
- 12. 結論

Document identity

Product	ODRE PQC
Version	0.2.9
Artifact	odre_pqc-0.2.9-py3-none-any.whl
Wheel SHA-256	A8AFA10EE0AFACEF1C0FAF55FF07B96C722920E5AEE8692F6F026E804F028697
Evidence manifest SHA-256	4AF2C88FDEA0CB1FB030E4AB6D5B41394CC52397664364233482E3EC14945F3B
Runtime cryptography	OpenSSL 3.5.8 / ML-KEM-768 / ML-DSA-65
Validated platforms	Windows Server 2022 AMD64; Ubuntu 24.04.4 LTS AMD64
Final audit verdict	ODRE_PQC_v0.2.9_FULL_DEVSEC_AUDIT_PASS

1. エグゼクティブサマリー

ODRE PQCは、保護対象のサーバールートに組み込むアプリケーション内蔵型のポスト量子セキュリティ境界である。暗号ランタイム管理、認証済みセッション確立、厳格なシーケンス、リプレイ耐性、要求・応答セマンティクス保護、ネイティブ成果物の信頼、ライフサイクル制御、fail-closed強制を小さな統合面の背後で提供する。

v0.2.9は本文記載のSHA-256で識別される封印済みクロスプラットフォーム候補である。同一wheelがWindows Server 2022 AMD64とUbuntu 24.04.4 LTS AMD64で新規の総合開発セキュリティ監査に合格した。実施範囲で新たに確認されたCritical、High、Mediumの製品欠陥は0件だった。

本書は絶対的安全性を主張しない。PASSは指定成果物、プラットフォーム、脅威モデル、構成、試験範囲に限られる。本番導入は別の運用判断とリスク評価を要する。

2. 製品の目的と範囲

本製品はTLS、認証、認可、安全な実装、パッチ、ホスト強化、バックアップ、監視を置き換えない。選択した業務ルートの前に追加の境界を設け、PQC境界が要求を受理した場合にのみ保護ハンドラーを実行する。

統合モデルは意図的に小さい。初期化、doctor、verifyを行い、install(app)でアプリに登録し、サーバー起動後に認証済みstatusを確認する。OS差異は製品内部のアダプターとネイティブランタイムバンドルで処理する。

Integration model

1	odre-pqc init
2	odre-pqc doctor
3	odre-pqc verify
4	from odre_pqc import install install(app)
5	server start → odre-pqc status

3. アーキテクチャ

境界は、アプリ統合層、受入制御と意味バインディング、ハイブリッドPQCハンドシェイク・セッション層、リプレイ・シーケンス状態、保護要求・応答envelope、OS別ネイティブ信頼制御、認証済みライフサイクル・状態報告から成る。

wire契約はodre-pqc/3として版管理される。ハンドラーが観測する保護要求の意味は認証済み内部意味と一致する。応答status、順序付きheader、cookie、bodyは保護フレーム内に置かれ、外側は限定された転送メタデータのみである。

配布は単一Python

wheelとOS別ランタイムバンドルで構成する。封印パッケージはメタデータ、manifest、native archive、完全性検査を正確なリリースIDに結び付ける。

4. 暗号プロファイル

監査済みランタイムはOpenSSL 3.5.8、OpenSSL_version_num 0x30500080である。両方の対象OSで実際のML-KEM-768、ML-DSA-65自己試験とハイブリッドハンドシェイクがPASSした。

保護ルートではPQC不能時にclassical-onlyへ黙って降格しない。provider、鍵、session、replay状態、native trust、runtime healthが契約を満たさなければ、業務ハンドラーの前で経路を遮断する。

5. セキュリティ契約

中核はfail-closedである。不正・曖昧な入力、replay・sequence違反、session・route不一致、未認証status、安全でないnative object、初期化失敗、危険な終了遷移を保護実行成功に変換しない。

認証済み要求意味とハンドラー観測意味は一致する。保護応答は機密性・完全性を保つ。重要なOS実行物とnative libraryは信頼済みobjectに結合する。ON statusは稼働中instanceと新鮮な状態に認証される。security resourceは受理済み要求より長く存続する。

6. 脅威モデルと信頼境界

監査はnetwork tamper、replay・並行性、malformed・oversized input、意味混同、応答metadata漏えい、crash・restart、local file置換、symbolic link・reparse操作、dependency・provider注入、lifecycle raceを対象とした。

基盤OS、CPU、Python runtime、正規管理者が完全侵害されていないことを前提とする。悪性kernel、無制限administrator、物理抽出、受理後のapplication logic欠陥、範囲外DoS、将来の暗号解読突破への防御は主張しない。

7. 検証と監査結果

封印wheelの新しい複製をhash-lockでinstallし、開始・終了SHA-256が同一であることを確認した。過去報告を新しいPASS証拠として再利用せず、監査中に製品byteを変更しなかった。

静的レビューはPython 38ファイル・7,160行、metadata、RECORD、platform support、両native manifestとruntime archiveを含む。wheel RECORDは45/45、混入0。Python dependency 19件への当時のadvisory照会はerror 0、返却された脆弱性record 0だった。

監査harnessの問題6件は製品欠陥から分離した。harness修正後に該当gateを再実行し、封印wheelは変更していない。

Published audit metrics

Metric	Windows	Ubuntu
Platform verdict	PASS	PASS
Replay-race requests	1,280	2,880
Double handler execution	0	0
Native load attempts	3,000	-
Atomic replacements observed	1,062	-
Junction create/remove cycles	3,000	-
Late-promotion parent swaps	-	600 / 600
Untrusted load / misbinding	0	0
Unresolved Critical / High / Medium	0 / 0 / 0	0 / 0 / 0

8. クロスプラットフォーム結果

Windowsではfresh init、second-init防止、doctor、verify、status、logon session遷移、replay race、request/response binding、ACL trust、status認証、shutdown resource lifetime、protocol tamper、crash recovery、native load stressを検証した。

Ubuntuではfresh init、negative diagnosis、real PQC、replay race、admission fuzz、malformed・oversized input、HTTP smuggling形状、response secrecy、WebSocket fail-closed、native object trust、concurrent init、worker collision、graceful/forced restart、parent-object raceを検証した。

9. リリース規律と証拠

ODRE PQCは不変のリリースIDを採用する。監査成果物はversionとSHA-256で固定する。byteが変われば新成果物と新検証サイクルが必要であり、同じversion名で再発行しない。

証拠はproduct finding、harness issue、environment issueを分離する。v0.2.9は発見製品欠陥0、修正製品欠陥0、環境問題0、未解決Critical/High/Medium 0。本番network接触0、本番変更なしである。

10. 導入ガイドンス

運用者はinstall前にwheel SHA-256を確認し、対応OS・Python baselineを使用し、管理されたfresh環境でinit、doctor、verifyを実行する。その後install(app)を登録し、起動後に認証済みstatusを確認してから保護trafficを有効化する。

別途TLS、認可、application security review、secret管理、host patch・hardening、logging、monitoring、backup、rollback、change controlが必要である。開発セキュリティ監査PASSは本番リスク評価の代替ではない。

11. 公開範囲

公開版はprivate key、secret、本番topology、顧客data、正確な内部path、運用ID、exploit script、全harness source、攻撃コストを実質的に下げる手順を除外する。一方、外部評価に必要なarchitecture、security contract、artifact ID、試験範囲・数値、限界は開示する。

12. 結論

ODRE PQC v0.2.9は封印済みクロスプラットフォームのアプリ内蔵PQCセキュリティ境界である。指定wheelは両公式OSで記載の総合開発セキュリティ監査に合格した。証拠が支持する最強の主張は限定的かつ再現可能であり、当該条件下でgateを満たし、確認済み未解決Critical、High、Medium製品欠陥は0件である。

Artifact verification

SHA-256

A8AFA10EE0AFACEF1C0FAF55FF07B96C722920E5AEE8692F6F026E804F028697

Evidence manifest SHA-256

4AF2C88FDEA0CB1FB030E4AB6D5B41394CC52397664364233482E3EC14945F3B

Verification command

```
python -m pip hash odre_pqc-0.2.9-py3-none-any.whl
```

Publication note

Prepared from the sealed v0.2.9 full development-security audit record. Public claims are deliberately scoped to the exact artifact and executed evidence. ODRE AI · Korea · 2026